

Introduction to the module and The CISO's briefing

Ten sessions to learn how to govern, not just how to secure

Session objectives

By the end of this first sequence:

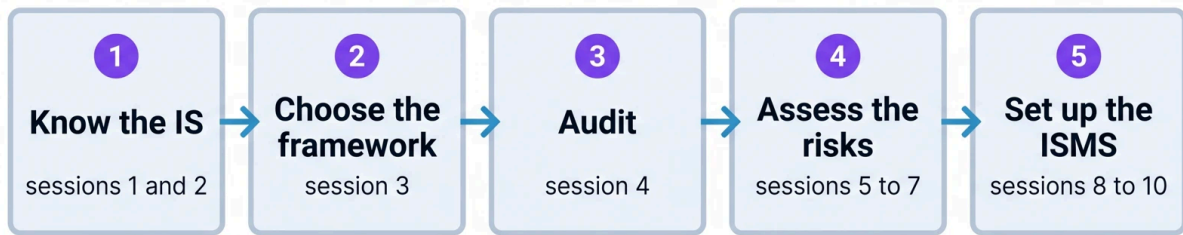
- **Situate** the module: its guiding thread, its business case, its deliverables and its grading scale
- **Take on** the role of Group CISO (RSSI Groupe) of MERIDIAN for ten sessions, with everything this position implies in terms of posture before decision-makers
- **Define** four starting notions: the CISO posture, the governance diagnosis, inter-subsidiary arbitration and systemic risk
- **Conduct** a first diagnosis: three files on a desk, three decisions to characterize

Prerequisites

- Those of the syllabus, and nothing more: general knowledge of systems and networks, basic notions of information security, and the habit of reading and writing carefully. Everything else is built here.

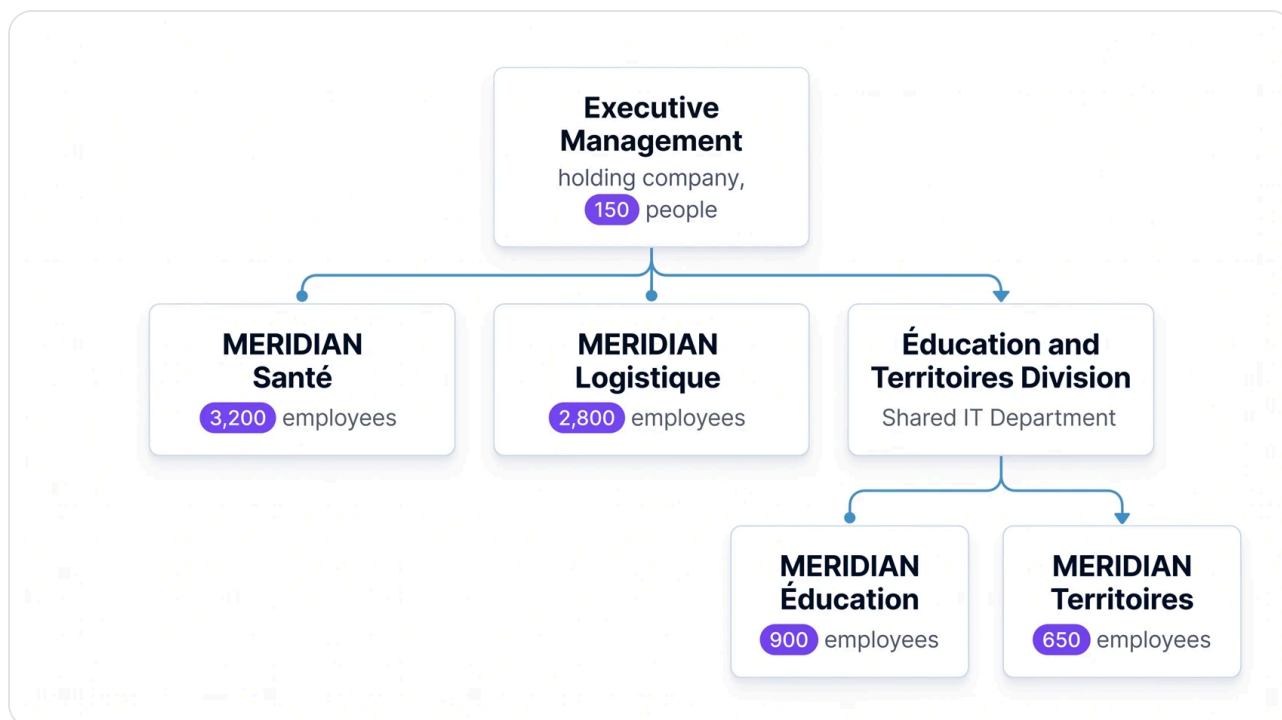
The module on one page

This module follows the real cycle of a security officer taking up a new position: first knowing the information system, then choosing a framework, auditing, assessing the risks, and finally establishing and running a security management system. Ten sessions, each with the same rhythm: theory in the morning, tool-based practice in the afternoon, and a quarter of an hour of strategic writing to close the day.



The module's path: five moves, ten sessions.

No throwaway examples here. The entire course plays out in a single business case, the MERIDIAN group: a multi-sector group of about 7 700 employees, a holding company of 150 people at headquarters and four subsidiaries. MERIDIAN Santé (healthcare subsidiary), 3 200 employees and 4 care facilities. MERIDIAN Logistique (logistics subsidiary), 2 800 employees and 6 warehouses. MERIDIAN Éducation (education subsidiary), 900 employees for 45 000 user accounts. MERIDIAN Territoires (local government services subsidiary), 650 employees serving some thirty client local authorities. The Éducation and Territoires subsidiaries share a pooled IT department, the « MERIDIAN Éducation & Territoires » division: this detail will produce interesting governance situations. And the role, from day one to the final defense: Group CISO, newly appointed, reporting to Executive Management. Everything that happens in this module happens from this chair.



The MERIDIAN group: four subsidiaries, and one division with a shared IT department.

The module's product, precisely: a cumulative MERIDIAN dossier, in which each session builds on the previous one. Each session produces its documents, scoping note, mapping, audit report, and from session 5 onward, five numbered deliverables, D5 to D9, one per session up to the ninth; the whole feeds the group report and the final defense. To this is added the strategy note, a single document of three pages at most, enriched for fifteen minutes at the end of each afternoon: its session N version contains all subsections 1 to N, nothing is ever deleted from it, everything in it can be amended; it is the document of a CISO who thinks over the long term, and the one defended at the final defense. The module's grading scale, out of 100 points:

ASSESSMENT	WEIGHT	WHEN
Nine end-of-morning quizzes	20 points	Each theory session, average retained
Individual oral exam on a governance point	15 points	Session 6, topic drawn at random
Group progress oral	10 points	Session 6, progress review of the dossier
Group report	30 points	Submitted at the end of the module
Security strategy note	10 points	Three pages, enriched every afternoon
Final defense	15 points	Session 10, before the group security committee

None of these assessments rewards recitation: oral exams, report and final defense evaluate the ability to analyze, arbitrate and defend decisions. That is the expected level, and it is the thread of everything that follows.

Four notions to begin with

Before the first exercise, the day's vocabulary: that of the Group CISO's profession.

The CISO posture, first, because it conditions everything else. The problem it names: a security officer who sees themselves as a technical expert talks about ports and patches to executives who decide in terms of risks, costs and liabilities; each leaves the meeting convinced that the other understood nothing, and both are right. The CISO posture is the professional stance that consists of translating security into the language of decision-making; informing executives about the risks, proposing options with their cost and their consequences, and having matters decided at the right level rather than personally settling what is not one's to settle. Its limit, which is also its greatness: the CISO informs and proposes, but owns neither the budget nor hierarchical authority over the business lines; when the CISO wins, it is through the quality of the case files, never by decree.

The governance diagnosis, next. Faced with an organization, the technician's reflex is to look for vulnerabilities; the governor's reflex is to look for WHO DECIDES. A governance diagnosis is the methodical examination of the way security decisions are made: who makes them, at what level, under what rules, and what happens when nobody makes them. Its mechanics come down to three questions asked of every situation: who decided this, who should have, and where is it written? What it is not: a technical audit. An organization can have excellent firewalls and governance in ruins, and the reverse; this module begins with governance precisely because governance determines the durability of everything else.

Inter-subsidiary arbitration is the daily sport of a group CISO. The problem: two subsidiaries are each right from their own point of view, Logistique wants availability, Santé wants confidentiality, and their disagreement blocks a joint project. Inter-subsidiary arbitration is the decision made at group level, under rules known in advance, when the legitimate interests of subsidiaries conflict. The mechanics matter more than the outcome: without a rule written BEFORE the conflict, arbitration happens by balance of power, and the loser contests it. What arbitration does not do: prove a subsidiary wrong; it gives priority to a group interest, which is a different sentence.

Systemic risk, finally, the one that justifies a group appointing a Group CISO. A risk is systemic when a failure at one point spreads to the whole, because everyone depends on the same thing. The real example the entire world has pondered: the SolarWinds affair, in 2020, where the booby-trapped update of the Orion product affected about 18 000 public and private customers, each of whom had trusted the same vendor. At the scale of a group like MERIDIAN, systemic risk wears more discreet faces: an IT department shared between two subsidiaries, a flow between two systems, a common service provider. Beware of the word's scope: finance has its own definition of systemic risk, irrelevant here; in this module, it refers to propagation through common dependency within an ecosystem.

The diagnosis's three-question reflex, to adopt starting today: who decided, who should have, where is it written. It fits on a metro ticket and it defuses half the confusing situations a career will bring.

The module's acronyms, in one place

The module uses acronyms the way professionals use them. Each is spelled out at its first appearance in a session; here they are gathered in one place, for future reference.

ACRONYM	FULL NAME	WHAT IT IS
ANSSI	Agence nationale de la sécurité des systèmes d'information (the French national cybersecurity agency)	The agency that publishes the guides this module builds on, including EBIOS Risk Manager and the mapping guide, and that will be the supervisory authority under NIS 2.
CNIL	Commission nationale de l'informatique et des libertés	The French data protection authority. It monitors the application of the GDPR and issues the sanctions this course cites.
PSSI	Politique de sécurité des systèmes d'information (information systems security policy)	The document through which management commits itself, and against which every subsidiary rule is checked. MERIDIAN's is drafted in session 9.
RGS	Référentiel général de sécurité (general security framework)	The framework that is mandatory for administrative authorities' online services. It concerns the Territoires subsidiary.
HDS	Hébergeur de données de santé (health data hosting provider)	The certification required to host health data. It concerns the Santé subsidiary.
ReCyF	Référentiel Cyber France	The framework ANSSI has been publishing since March 2026, ahead of the NIS 2 transposition law. Its security objectives will be made mandatory by decree; its acceptable means of compliance will not.
CESIN	Club des experts de la sécurité de l'information et du numérique (French club of information security and digital experts)	The association whose annual barometer provides several of this module's figures.
EBIOS RM	EBIOS Risk Manager	The French method for risk assessment and treatment, published by ANSSI. Its five workshops structure sessions 5 to 7.
DICT	Disponibilité, intégrité, confidentialité, traçabilité (availability, integrity, confidentiality, traceability)	The method's four security needs. Session 2 uses them to rate business assets.

Case study: three files on the new Group CISO's desk

Scenario and problem statement

Monday, the MERIDIAN Group CISO's first day. No group PSSI: each subsidiary has always managed its security as it sees fit, and the position was created precisely to remedy this. On the desk, three files left by Executive Management, with this note: "Tell me what you think on Thursday."

File 1. The Logistique subsidiary requests the opening of a permanent flow between its warehouse handheld scanners and the Santé subsidiary's inventory management system, to streamline emergency supply for the care facilities. Santé refuses: "their equipment is not trusted". The project has been blocked for three months, and each subsidiary is holding its ground.

File 2. The IT Director of the Éducation subsidiary proposes entrusting the security monitoring of the four subsidiaries to the tool he already uses, "since the IT department is already shared with Territoires, we might as well centralize everything with us, it is the cheapest option".

File 3. The group's Internal Auditor, Governance and Audit sector, reports having asked the Santé subsidiary three times for its register of administrator accounts, without response, and proposes "taking over the management of these accounts to guarantee they are kept clean".

Guided questions

1. **Characterize** each file using the day's vocabulary: which one is primarily a matter of inter-subsidiary arbitration, which one carries a systemic risk, which one poses a governance problem in the strict sense, that of "who decides"? Justify in one sentence per file (a file may fall under two categories; if so, state which one dominates).

2. **Apply** the three diagnostic questions to file 3: who decided what, who should have, where should it be written?

3. **Analyze** file 2: the cost argument is real, the shared IT department exists; what would the proposal nevertheless do to the group's risk profile?

4. **Formulate**, for Thursday, the posture response: for each file, one sentence stating what the Group CISO proposes that Executive Management DECIDE, without personally settling what is not the CISO's to settle.

Working method

Fifteen minutes alone, ten minutes comparing in pairs, five minutes pooling results. The right technical answers are not in the files: what the files contain is the right governance questions. And language is to be watched: an answer to question 4 that contains a network configuration term signals a change of profession along the way.

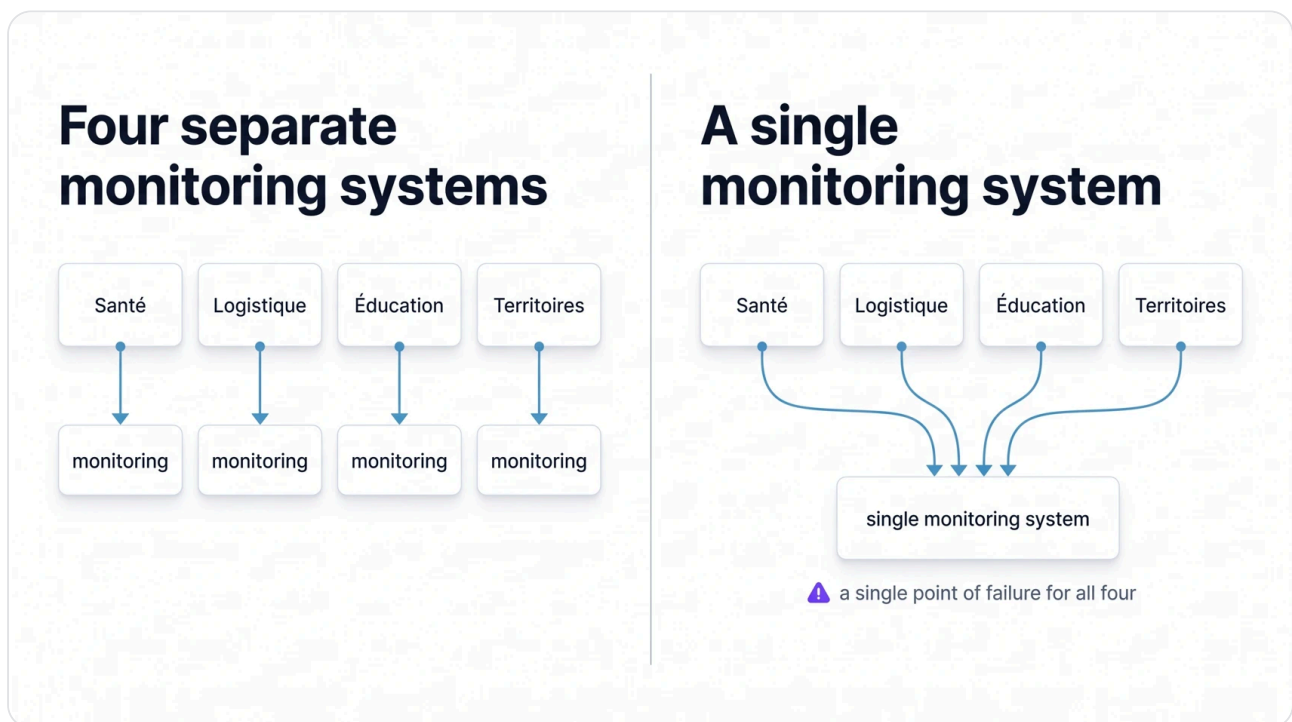
Answer keys and assessment criteria

Reasoned answer key

Question 1. File 1 is inter-subsidary arbitration in its purest form: two legitimate interests, supply availability versus the protection of a healthcare information system, and no pre-existing rule to decide between them, hence three months of deadlock. File 2 is dominated by systemic risk: centralizing the monitoring of all four subsidiaries on one subsidiary's tool creates exactly the common dependency whose price SolarWinds demonstrated in 2020, and the economic argument changes nothing about the topology of the risk. File 3 is the governance problem in the strict sense: nobody can say who must answer for Santé's register of administrator accounts, and the proof is that the auditor proposes to take charge of it personally.

Question 2. Who decided? Nobody: the register is neither kept nor formally refused, it is ignored, and the absence of a decision IS the decision. Who should have? The Santé subsidiary for keeping it, under a group rule that does not yet exist; and the obligation should have been decided at group level. Where should it be written? In the group's future governance framework, with a named owner, and that is exactly what the afternoon builds. As for the auditor's proposal to "take over": it points back to this morning's lecture, because a controller who becomes the operator of what they control ceases to be able to control it.

Question 3. The proposal would turn a budget choice into a concentration of risk: a single team, a single tool, a single point of failure for the security visibility of all four subsidiaries, and a shared IT department that would combine operating itself AND monitoring itself. The diagnosis does not say "no": it says the decision is not economic in nature but risk in nature, and that it must be informed as such before being made. If the group centralizes, it will be with full knowledge of the facts, with safeguards, not because it was the cheapest option.



Four separate monitoring setups, or a single point of failure for all four.

Question 4. Three possible posture sentences, to compare afterwards. File 1: "I propose that the group adopt a rule for arbitrating inter-subsiary flows, and that this flow serve as its first application case; I will present the rule on Thursday." File 2: "I propose characterizing the concentration risk before any decision: I will bring an analysis by the end of the month; the cost question will come after the risk question." File 3: "I propose that keeping the register be an obligation of the subsidiary with a named owner, and that audit remain in a control role: I will submit the corresponding rule to the next committee." The common point, and the criterion: each sentence designates a DECISION to be made and its LEVEL, and none of them configures anything.

Assessment matrix

CRITERION	INSUFFICIENT	EXPECTED	EXCELLENT
Characterization of the files	Categories applied mechanically without justification	Three justified characterizations, with the dominant category identified	Same, with the overlap of categories made explicit on one file
Three diagnostic questions	Technical answers	The three questions asked and answered on file 3	Same, with "the absence of a decision is a decision" stated
Analysis of file 2	"It is cheaper so yes" or "it is risky so no"	The debate shifted from cost to concentration risk	Same, with the SolarWinds parallel used judiciously
Posture (question 4)	The CISO decides alone or stays technical	Three sentences that have the decision made at the right level	Same, with each sentence announcing the case file that will come to support it